Profile Update (HR): HR user from Obian Outsourcing can access [view / edit] Ebanco Limited's data

Done Done 1

Description

Description

While testing OBY-14 (Profile Update (HR)), I ran the test case for OBY-47 (HR cannot access other company). HR users should only manage their own profile, their own company profile and their own company's employee records. I logged in as an HR user from Obian Outsourcing and tried to access data belonging to Ebanco Limited by company ID in the URL. The system [showed me the data / let me save changes] instead of blocking the request. This means company data is not properly separated.

Preconditions

1. Two companies exist: Obian Outsourcing and Ebanco Limited, each with its own employees.
2. An active HR user exists for Obian Outsourcing: estherodiaka20@gmail.com
3. Ebanco Limited has an employee record and company profile: ebanco@gmail.com.
4. I was logged in as the Obian Outsourcing HR user.

Test data

- Logged-in user: estherodiaka20@gmail.com
- Target data: ebanco@gmail.com.

Details

Due date
30 Oct 2026

Start date
8 Nov 2026

Assignee
EO Esther Odiaka

Parent
OBY-1 OBY HRIS (Human Resour...

Sprint
OBY Sprint 2

Labels
Labels: access-control, hr, multi-tenant, security

Team

Story point estimate

Steps to reproduce

1. Log in as the HR user for Obian Outsourcing.
2. Open a company profile in Obian Outsourcing and note the URL
3. Change the ID to an Ebanco Limited employee or company ID .
4. Press Enter, or send the request from the app.
5. I Tried to edit a field and save
6. Observe the result.

Expected result

- The request is rejected with a 403 (or 404) and no Ebanco Limited data is shown.
- A clear message such as "You do not have access to this record" is displayed.
- No Ebanco Limited data is changed.
- The blocked attempt is logged (who, what, when), as the acceptance criteria require.

Actual result

The Ebanco Limited API returned 200 with Ebanco Limited data.

Impact

- An HR user can see or change personal and payroll data of employees in other companies.
- Private company details (name, logo, address) of Ebanco Limited could be changed by an outsider, which breaks the rule that only that company's HR/Admin can edit them.
- It could lead to a data breach and legal and privacy problems.
- Changes made across companies may not be logged correctly, which breaks the audit trail rule.

Reporter

EO Esther Odiaka

Development

Start coding

Automation

Created 1 month ago

Updated 1 month ago

Resolved 1 month ago

Frequency: [Always, 3 out of 3 attempts / Intermittent]

Priority: Highest
Severity: Critical (broken access control / cross-company data exposure)
Environment: [Staging/QA], [browser and version], [OS], [build number]

Evidence attached

- Screen recording of the full flow
- Screenshot of Ebanco Limited's data being displayed
- Console/network logs showing the request and the response status, e.g. 200 instead of 403
- IDs used: [Obian Outsourcing ID], [Ebanco Limited ID]

Suggested fix
I recommend checking on the server, for every request, that the record belongs to the logged-in HR user's company, instead of trusting the ID sent from the page or API. Return 403 for any mismatch and log the attempt. Please also check that other endpoints (view, edit, deactivate employee, company profile) follow the same rule.

Retest criteria

- An HR user from Obian Outsourcing cannot view or edit Ebanco Limited's employee records or company profile.
- The blocked request returns 403/404 with a clear message and is logged.
- HR can still edit their own profile (OBY-46), their own company profile (OBY-49) and their own employees (OBY-50).
- I will also regression-test OBY-48 (Deactivate employee) across companies.

Note: Because this is a security issue, I'd like it prioritised. The parent story OBY-14 is already marked "Failed."

Hide full description

Add subtask Add linked work item

Attachments

All

Name	Date added	Added by
WhatsApp Image 2026-10-... jpeg	Oct 25, 2026	EO
WhatsApp Video 2026-10-2....mp4	Oct 25, 2026	EO
image-11-1024x479.png	Oct 25, 2026	EO

Activity Comments

All

Add a comment or press M